



RT Bank

Infrastructure multi-sites sécurisée

Stormshield ■ Apache HA ■ BIND9 ■ AD ■ Zabbix

Auteur

HONORINE Kylian

Cadre

SAE 4.Cyber.04

☰ Sommaire

1	Contexte et objectifs	1
2	Architecture réseau	1
2.1	Plan d'adressage	1
2.2	Stormshield EVA — interfaces	1
2.3	Matrice de flux	2
3	Frontaux web — HAProxy + Apache + TLS	2
3.1	Schéma fonctionnel	2
3.2	Configuration HAProxy	2
3.3	Apache backend (web1 & web2)	3
4	DNS — BIND9 maître / esclave	3
4.1	Rôles	3
4.2	Configuration du serveur maître	3
4.3	Zone rt-bank.re	4
4.4	Configuration du serveur esclave	4
5	Annuaire — Active Directory rtbank.re	4
5.1	Topologie	4
5.2	Stratégies appliquées	4
5.3	Structuration des OUs	5
6	Supervision — Zabbix	5
6.1	Architecture	5
6.2	Templates et alertes clés	5
6.3	Notifications	5
7	Durcissement — recommandations ANSSI	6
7.1	Systèmes Linux (Debian 12)	6
7.2	Windows Server (DC1)	6
8	Tests d'intrusion et contre-mesures	6
8.1	Méthodologie	6
8.2	Findings principaux et remédiations	7
9	Synthèse	7
10	Conclusion	7

1 Contexte et objectifs

🎯 Mission

RT Bank — agence bancaire fictive — déploie une infrastructure multi-sites entre Saint-Denis et Saint-Pierre. Objectifs : sécurité par défaut, haute disponibilité, exploitation supervisée, et conformité aux recommandations **ANSSI**.

Périmètre couvert :

- Pare-feu **Stormshield EVA** segmentant DMZ / LAN-Clients / LAN-Serveurs / WAN
- Cluster Apache + HAProxy avec terminaison TLS en DMZ
- DNS **BIND9** maître/esclave pour le domaine **rt-bank.re**
- **Active Directory** **rtbank.re** avec DC primaire à Saint-Denis et RODC à Saint-Pierre
- Supervision **Zabbix** et durcissement système
- Pentest et plan de contre-mesures

2 Architecture réseau

2.1 Plan d'adressage

Zone	VLAN	Réseau	Rôle
WAN	–	192.168.41.0/23	Sortie Internet
DMZ	100	10.10.10.0/24	Services exposés (web, mail relay)
LAN-Serveurs	200	10.10.20.0/24	DC, DNS, fichiers, Zabbix
LAN-Clients	300	10.10.30.0/24	Postes utilisateurs
MGMT	999	10.10.99.0/24	Administration équipements

2.2 Stormshield EVA — interfaces

Iface	Zone	IP	Description
1	WAN	192.168.41.65/23	Lien opérateur
2	DMZ	10.10.10.1/24	Frontaux web
3	LAN-Clients	10.10.30.1/24	Postes
4	LAN-Serveurs	10.10.20.1/24	Backoffice

2.3 Matrice de flux

Source	Destination	Service	Action	Justification
LAN-Clients	DMZ (HAProxy)	TCP/443	✓ OK	Accès web interne
WAN	DMZ (HAProxy)	TCP/443	✓ OK	Web public
LAN-Clients	LAN-Serveurs (DC)	TCP/389+88 + UDP/53	✓ OK	Auth + DNS
DMZ	LAN-Serveurs	TCP/3306	✓ OK	SQL applicative
DMZ	LAN-Clients	Any	✗ Refus	Isolation stricte
WAN	LAN-*	Any	✗ Refus	Aucun accès direct

3 Frontaux web — HAProxy + Apache + TLS

3.1 Schéma fonctionnel

Chaîne de traitement

Internet → Stormshield (NAT 443) → HAProxy (termination TLS, équilibrage) → 2 Apache backends (web1, web2)

HAProxy joue trois rôles : terminer le TLS (1 seul certificat à gérer), répartir la charge (round-robin avec health checks), et masquer le nombre réel de frontaux.

3.2 Configuration HAProxy

```
global
    daemon
    maxconn 4096
    log /dev/log local0

defaults
    mode http
    timeout connect 5s
    timeout client 30s
    timeout server 30s
    option httplog
    option forwardfor

frontend https_in
    bind *:443 ssl crt /etc/haproxy/certs/rtbank.pem
    http-request redirect scheme https unless { ssl_fc }
    default_backend web_pool

backend web_pool
    balance roundrobin
    option httpchk GET /health
    server web1 10.10.10.11:80 check
    server web2 10.10.10.12:80 check
```

3.3 Apache backend (web1 & web2)

Apache écoute sur le port 80 en interne uniquement. La redirection X-Forwarded-Proto est lue depuis HAProxy pour générer correctement les liens absolus.

```
<VirtualHost *:80>
    ServerName www.rt-bank.re
    DocumentRoot /var/www/rtbank

    # Endpoint sante pour HAProxy
    Alias /health /var/www/health
    <Directory /var/www/health>
        Require all granted
    </Directory>

    <Directory /var/www/rtbank>
        Options -Indexes +FollowSymLinks
        AllowOverride None
        Require all granted
    </Directory>
```

```
ErrorLog ${APACHE_LOG_DIR}/rtbank-error.log
CustomLog ${APACHE_LOG_DIR}/rtbank-access.log combined
</VirtualHost>
```

4 DNS — BIND9 maître / esclave

4.1 Rôles

Serveur	Adresse	Rôle
ns1.rt-bank.re	10.10.20.5	Master rt-bank.re (Saint-Denis)
ns2.rt-bank.re	10.10.20.6	Slave rt-bank.re (Saint-Pierre)

4.2 Configuration du serveur maître

```
options {
    directory "/var/cache/bind";
    listen-on { 127.0.0.1; 10.10.20.5; };
    allow-query { 10.10.0.0/16; };
    forwarders { 1.1.1.1; 9.9.9.9; };
    recursion yes;
    dnssec-validation auto;
};

zone "rt-bank.re" {
    type master;
    file "/etc/bind/db.rt-bank.re";
    allow-transfer { 10.10.20.6; };
    also-notify { 10.10.20.6; };
};
```

4.3 Zone rt-bank.re

```
$TTL 3600
@ IN SOA ns1.rt-bank.re. admin.rt-bank.re. (
    2026053001 ; serial
    3600 ; refresh
    900 ; retry
    604800 ; expire
    3600 ) ; minimum

    IN NS ns1.rt-bank.re.
    IN NS ns2.rt-bank.re.

ns1 IN A 10.10.20.5
ns2 IN A 10.10.20.6
www IN A 192.168.41.66 ; IP publique HAProxy
mail IN A 192.168.41.67
@ IN MX 10 mail.rt-bank.re.
```

4.4 Configuration du serveur esclave

```
zone "rt-bank.re" {
    type slave;
    masters { 10.10.20.5; };
    file "/var/cache/bind/db.rt-bank.re.slave";
};
```

5 Annuaire — Active Directory rtbank.re

5.1 Topologie

Réplication AD

- **DC1** — **Saint-Denis** (10.10.20.10) : DC principal, FSMO roles, schema master
- **RODC** — **Saint-Pierre** (10.10.20.11) : Read-Only Domain Controller pour le site distant

Un **RODC** (Read-Only DC) authentifie localement les utilisateurs autorisés sans pouvoir être source de propagation en cas de compromission — idéal pour un site distant moins protégé physiquement.

5.2 Stratégies appliquées

GPO	Effet
Password policy	14 caractères, complexité, expiration 90j, historique 24
Lockout policy	5 tentatives, 30 min de verrouillage
Audit policy	Logon/Logoff, Account Mgmt, Policy Change — tous succès/échecs
UAC	Niveau maximum sur les postes utilisateurs
LAPS	Mot de passe admin local unique par poste, rotation 30j

5.3 Structuration des OUs

```
DC=rtbank,DC=re
|-- OU=Sites
| |-- OU=StDenis
| | |-- OU=Users (collaborateurs)
| | |-- OU=Computers (postes)
| | '-- OU=Servers (serveurs)
| '-- OU=StPierre
| |-- OU=Users
| '-- OU=Computers
|-- OU=Groups
| |-- OU=Roles (RH, Compta, Direction, IT)
| '-- OU=Resources (accès partages, applis)
'-- OU=ServiceAccounts (comptes applicatifs)
```

6 Supervision — Zabbix

6.1 Architecture

Composant	Description
Zabbix server	10.10.20.20 — collecte centralisée
MySQL backend	sur le même serveur, base zabbix dédiée
Frontend	Apache + PHP, accès via HAProxy interne
Agents Zabbix	sur DC, DNS, frontaux web, pare-feu (via SNMPv3)

6.2 Templates et alertes clés

Métrique	Seuil d'alerte
CPU utilisation	> 85% pendant 5 min
RAM disponible	< 10% pendant 5 min
Disque /, /var, /srv	> 90%
Process critiques (apache2, named, haproxy)	Indisponible > 60s
Réplication AD	SYSVOL/NETLOGON non répliqué > 15 min
Certificat TLS	Expiration < 30 jours

6.3 Notifications

Trois canaux : mail SMTP via le relais DMZ pour les alertes « Information » et « Avertissement », webhook Mattermost pour les alertes « Haute », et SMS via passerelle dédiée pour les alertes « Critique ».

7 Durcissement — recommandations ANSSI

7.1 Systèmes Linux (Debian 12)

```
# Service indispensable au strict minimum
systemctl disable --now bluetooth cups avahi-daemon

# Pare-feu hôte (UFW) ferme par défaut
ufw default deny incoming
ufw default allow outgoing
ufw allow from 10.10.99.0/24 to any port 22 proto tcp
ufw enable

# Mises à jour automatiques sécurite
apt install -y unattended-upgrades
dpkg-reconfigure --priority=low unattended-upgrades

# SSH durci
sed -i 's/^#?PermitRootLogin.*/PermitRootLogin no/' /etc/ssh/sshd_config
```

```
sed -i 's/^#\?PasswordAuthentication.*/PasswordAuthentication no/' /etc/ssh/sshd_config
sed -i 's/^#\?X11Forwarding.*/X11Forwarding no/' /etc/ssh/sshd_config
systemctl restart sshd

# Auditd active
apt install -y auditd
systemctl enable --now auditd
```

7.2 Windows Server (DC1)

- Désactivation de SMBv1 (Set-SmbServerConfiguration -EnableSMB1Protocol \$false)
- Activation du **Credential Guard** et **LSA Protection**
- Blocage NTLMv1 / NTLMv2 fallback via GPO
- Activation Windows Defender ASR (Attack Surface Reduction)
- Journaux exportés vers le serveur Zabbix + retention 1 an

8 Tests d'intrusion et contre-mesures

8.1 Méthodologie

Trois phases : reconnaissance, exploitation, post-exploitation. Outils : nmap, gobuster, hydra, BloodHound, sqlmap. Périmètre : DMZ et services exposés.

8.2 Findings principaux et remédiations

Vulnérabilité	Contre-mesure
Énumération NSE (nmap -sV)	Filtrage applicatif sur le pare-feu, masquage de version Apache (ServerTokens Prod)
Bruteforce HTTP form	Rate-limiting HAProxy + fail2ban sur les logs Apache
Injection SQL (sqlmap)	Paramétrage des requêtes en backend, WAF ModSecurity activé en mode bloquant
Reconnaissance AD (BloodHound)	Tiering AD (Tier 0/1/2), suppression des chemins d'attaque vers DA
Kerberoasting / AS-REP roasting	Mots de passe service > 25 caractères, gMSA quand possible, Do not require pre-authentication désactivé
Mouvement latéral SMB	Désactivation SMBv1, signature SMB obligatoire, segmentation par VLAN

⚠ Constat majeur

Le risque résiduel le plus élevé porte sur **le facteur humain** — phishing ciblé, partage de mots de passe, branchement de matériel non maîtrisé. Une démarche de sensibilisation continue et des exercices red team réguliers sont indispensables.

9 Synthèse

Volet	Livrables
Réseau	Plan d'adressage, segmentation VLAN, matrice de flux
Sécurité	Stormshield (filtrage + NAT), durcissement ANSSI
Services	HAProxy/Apache HA + TLS, BIND9 master/slave, AD multi-sites
Supervision	Templates Zabbix, escalade multi-canaux
Pentest	Rapport <i>findings</i> + plan de remédiation

10 Conclusion

Cette SAE met en œuvre une infrastructure d'entreprise complète, depuis le filtrage en bordure jusqu'à la supervision applicative. La logique est invariante : **minimum de privilèges, défense en profondeur, traçabilité**. Aucun composant n'est seul : chaque service critique (DNS, AD, web) est redondé, chaque flux passe par un point de contrôle, et chaque incident est instrumenté pour être détecté en moins d'une minute.

L'expérience la plus instructive a été le pentest : voir le réseau du point de vue de l'attaquant, mesurer l'écart entre la documentation et la réalité, et constater que le maillon faible est presque toujours organisationnel avant d'être technique.

« La sécurité, c'est un processus — pas un produit. »
— Bruce Schneier